

ALSO SEE Newsletter of April 10, 2024

[doc. web n. 10002533]

Provision of March 21, 2024

Register of provisions

n. 195 of March 21, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stazione, President, Prof.

Ginevra Cerrina Feroni, Vice President, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing "Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter "Code");

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor for the protection of personal data, approved by Resolution of the Guarantor No. 98 of 4/4/2019, published in G.U. No. 106 of 8/5/2019 and in www.gpdp.it, doc. web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, in www.gpdp.it, doc. web n. 1098801;

REPORTING Attorney Guido Scorza;

PREMISED

1. The investigative activity.

Following press reports and notifications of personal data breaches sent in the first days of XX by the Lazio Region and the Regional Council of Lazio, pursuant to Article 33 of the Regulation, the Authority learned that the information

systems managed by the company LAZIOcrea S.p.a. (hereinafter “Company” or “LAZIOcrea”), as data processor on behalf of the Region and various entities of the regional health service, including that of the Local Health Authority Rome 3 (hereinafter “Authority”), had been the subject of a cyberattack, caused by ransomware malware.

Considering the high number of affected individuals involved and the nature of the personal data subject to breach, the Office requested information from the aforementioned Company regarding the cited personal data breach, as well as the security measures adopted, with particular reference to the technical and organizational measures taken to ensure the availability and resilience of the processing systems and services and the timely restoration of the availability and access of personal data in the event of an incident (notes of XX and XX to which the Company responded with notes of XX and XX, XX and XX).

Subsequently, an inspection activity was carried out against the Company in the months of XX and XX.

Thereafter, in the months of XX, XX, XX, XX, and XX, further investigative activities were conducted through the acquisition of information from some data controllers involved in the aforementioned breach, including the aforementioned Authority which, based on the documentation provided by LAZIOcrea, appeared to be involved in the breach of personal data.

With the notification of XX, the Lazio Region declared that it had “suffered a cyberattack that compromised the functionality of the services offered by the regional CED; a technical verification of what happened is currently underway, and at this time it is not possible to determine whether there has been a loss of data, the categories and approximate number of records of the personal data in question, and the possible consequences of the personal data breach.”

In a note dated XX, the aforementioned Company, in response to the cited request for information made by the Office, stated that:

“following the cyberattack that occurred on the night of July 31 last (caused by ransomware malware), some information systems of the Lazio Region were deactivated, temporarily rendering the related services, data, and information processed unavailable”; it was “committed to providing support for the ongoing investigation by law enforcement and other competent national security authorities”; “analysis activities were underway to ascertain the scope and extent of the breach of the personal data

processed [...] once the details of the events are fully understood, including the historical and technical aspects”; it was “necessary to operate in parallel to restore services, implementing all the measures and precautions to prevent the systems themselves from suffering another attack.”

Subsequently, in a note dated XX, the Company has notified, in a preliminary manner, the violation of personal data, availing itself of the option to provide further information in subsequent phases, provided with the subsequent integrations of XX and XX. In the aforementioned notification, it was particularly stated that:

“the attack began in the late evening of July 31 but became evident in the early hours of the morning of August 1 when some virtual machines became unusable. This is a cyber attack aimed at the propagation of malware belonging to the family known as ‘RansomEXX’, also known as ‘Defray777’, which was promptly reported by our cybersecurity service to the CSIRT and the CNAIPIC with a notification/report via email on August 1 at 10:22 AM. The attack affected the application layer of the data center virtualization, forcing the Company to take all systems offline in order to ensure that the integrity and confidentiality of the data were not compromised”;

“the essential services related to emergency activities of 112, 118, transfusion centers, Emergency Room, and Civil Protection were never interrupted or compromised even during the investigative activities aimed at ascertaining the extent of the incident. In part because they were segregated from other applications”;

“all other services and applications residing on the data center have been restored or will be restored [...] after verifying the removal of any residual and/or possible contamination and having reconfigured the systems concerning the pre-existing security architecture. For informational purposes, vaccination activities against Covid have continued, as well as the booking service for the aforementioned vaccines was restored within four days before new administration slots became available. Slots that at the time of the incident were already occupied until the subsequent August 13. Starting from August 16, third-party application providers residing in the data center will have the opportunity to reinstall their systems to resume the provision of related services”;

“the origin of the incident seems, at this stage, to be traceable to the injection, on one or more client computers operating remotely via VPN, of malicious software that created a communication channel (backdoor) between the infected client computers and the group of cyber criminals. The cyber criminals, exploiting the same credentials, were thus able to subsequently access the corporate network and from there move ‘laterally’ within the so-called subnets, performing an escalation on administrative accounts that were probably identified by intercepting low-level data packets occurring on that network at the time of user login. These criminals seem to have utilized the skills of another group of hackers to whom the encrypted passwords were passed. This further group of criminals, exploiting a presumed vulnerability of the operating system, managed to decrypt a password that was then matched to one of the four user IDs with administrative privileges previously identified by the hackers”;

“experts then conducted checks to assess whether the attack, which did not compromise the integrity and confidentiality of the data, had allowed the intruders to appropriate the same through exfiltration and/or transfer techniques. The analyses confirmed that as of today, exfiltration can be excluded since no data flows to the outside were detected during the attack period”;

“the files found in the temporary directories are indeed derived from the automation of the tools used for the attack and aimed primarily at verifying the system architecture and the inventory of the applications present to better prepare the attack depending on the detected system configurations. Moreover, the firewall policies active during the attack did not allow the use of FTP, SSH, and SFTP protocols from within the data center perimeter to the Internet. In any case, activities of ‘Cyber Threat Intelligence’ are still ongoing by the consultants engaged to ensure that no information belonging to Laziocrea is made public, even if related to data already known before the attack. At the moment, despite the expiration of the ultimatum, no new information has been made available on the web, particularly on the so-called illegal ‘dark web’”;

“the data and information present in the databases have therefore been unavailable for the time necessary to restore the applications and secure the perimeter of the data center through its reconfiguration. For some systems, the information will remain unavailable until reactivation, which will occur completely over the next few days. Therefore, there are no serious limitations to the freedoms and fundamental rights of the interested parties.”

With the supplementary notification of XX, the Company provided the list of applications and services involved in the violation – indicating those restored immediately and those in the process of being restored – and the list of those that remained active as they were segregated from the infrastructure subject to the attack, stating, in particular, that:

based on “the investigations conducted by the internal Cyber Security structure, by the CSIRT, by the CNAIPIC, and by Leonardo S.p.A., it appears that the attack, which began at 3:05 PM on the afternoon of July 31, 2021, was originated from the compromise of an account belonging to a regional employee whose access credentials were stolen through malicious artifacts.

(back door) installed on the personal computer used for remote connections to the corporate network necessary for smart working”;

“forensic analysis activities have established that the artifacts were injected on March 25, 2021, and that they were not detectable on the host computer by antivirus and malware software. During the forensic analysis of the copy of the computer in question, the scan still yielded a negative result despite the so-called 'signature database' of the antivirus/malware software being updated by forensic investigators to the most recent date of August 10. The user's remote connections to the corporate network were still protected by a VPN”;

“there were also attempts of anomalous access concerning six user accounts on the OWA interface of the email systems from April 12, 2021, until July 26, 2021. However, these attempts do not appear to be related to the incident and mostly resulted, with the exception of one account, in denial of access to the email service”;

“in conclusion, the attack was launched in the afternoon of Saturday, July 31, 2021, using the first compromised account and became perceptible when, in the early hours of the morning of August 1, the first malfunctions of some virtual machines in the Data Center began to occur”;

“the attack targeted the machines located in Room 'B' [of the data center managed by the Company], where various types of hardware are present for both computational purposes and in terms of storage and networking devices (essentially Cisco, Dell, Fortigate, etc.). Being modular machines and scalable in terms of equipment and computational and storage characteristics, they are managed by proprietary firmware on which the Microsoft Active Directory Hosts and VMWare & Microsoft Hyper-V operating environments have been installed. On this virtualization environment, virtual machines with Windows Server and Linux operating systems have been configured and installed to serve the services and applications necessary for the processing carried out by LAZIOcrea both as Data Controller and as Processor for other Controllers, and in particular for the Lazio Region.”

During the aforementioned inspection activities, the Company also stated that:

– “as a result of the forensic analyses conducted, it appears that, in March 2021, a malicious actor introduced a backdoor – unknown and undetected, neither at the time nor during the analyses, by more common antivirus and antispyware software – into the corporate laptop in use by [...] an employee of the Lazio Region, which was likely used to acquire the authentication credentials” attributed to the same employee;

– “on July 31, 2021, the aforementioned authentication credentials were used to remotely access the Company's network and to conduct the actions leading up to the cyber attack. In particular, the malicious actors carried out a series of scanning activities aimed at acquiring information about the network and the server systems present there. Within the scope of these activities, they identified the server with hostname 'RLWSIRIFT01' on which base software was installed for which no updates or security patches from the manufacturer were available. This circumstance was due to the need to ensure the operation of a legacy web application that required a specific version of the operating system and application server. By exploiting known vulnerabilities of the base software present on the

aforementioned server, the malicious actors were able to obtain authentication credentials with administrative privileges [...] used in the subsequent phases of the cyber attack”;

– “the Company became aware of the cyber attack through a report from a healthcare operator who, unable to access certain services provided by the Company, contacted the on-call system administrator for healthcare area services at around 05:00 on August 1, 2021. Following the report and the initial analyses conducted, the system administrator confirmed the significance of the security incident and proceeded to contact other system administrators, some of whom immediately went to the data center. At around 06:15 on XX, the report was brought to the attention of the director of the Company’s Infrastructure Systems Department”;

– “with reference to the initiatives taken following the detection of 'hostile activities' (2,189 alerts) by the 'Microsoft Windows Defender ATP console' on the evening of July 31, 2021, [...] during the activation of the SOC service of Leonardo S.p.a., this monitoring tool was not manned 24/7” and, therefore, “it was not possible to manage these alerts with 'greater' timeliness.”

In the documentation acquired during the investigation phase, the Company also provided the list of controllers on behalf of whom it processed the personal data involved in the breach, among which the Local Health Authority Roma 3 was also indicated (see notification of XX, attached to sections G, H, and I, and note of XX, attached to A7).

1.1 Measures in place at the time of the breach

With reference to the measures in place at the time of the breach, the Company stated that “the Data center and the corporate procedures for data security and protection are certified ISO 27001” (see notification of XX, p. 8 and attachment 6).

In particular, regarding the technical and organizational measures adopted to ensure the availability and resilience of the systems and services of

**treatment, as well as the timely restoration of the availability and access of personal data in the event of an incident, the Company has provided copies of the backup procedures, the business continuity and disaster recovery plan, the incident management process, and the personal data breach management procedure in effect as of July 31, 2021 (see note from XX, attachments C and D in response to the request for information from the Office of XX). **

During the inspection activities, the Company then stated that:

1. “It uses Microsoft’s Active Directory as its IT authentication system. This system is used for the authentication of users from the Company, the Region, and other external entities for access to systems authenticated to the domain (workstations and servers) and to certain web applications, as well as for remote access via VPN to the Company’s network,” specifying that “at the time when the personal data breach occurred, a multi-factor IT authentication procedure for VPN access was not in place”;
2. “It has defined different password policies for the various types of accounts used by the staff of the Company, the Lazio Region, and other entities. In particular, at the time when the personal data breach occurred, the passwords for accounts without administrative privileges had to consist of a minimum of 8 characters, contain characters from at least three categories (uppercase letters, lowercase letters, numbers, special characters), not coincide with the last four passwords, and be changed at most every 90 days; the passwords for accounts with administrative privileges had to consist of a minimum of 20 characters, contain characters from at least three categories (uppercase letters, lowercase letters, numbers, special characters), not coincide with the last four passwords, and be changed at most every 30 days”;
3. “It has implemented measures to segregate the systems present within the data center. In particular, the servers hosting the various databases are connected to segregated networks compared to other networks, which is why the cyber attack at the end of July did not involve the data stored within such servers. Similar segregation measures are applied to servers that provide particularly critical services [...] or dedicated to specific clients [...]”;

4. Regarding the security measures related to network segregation in place at the time of the personal data breach, “there are two levels of firewalling: the first is dedicated to filtering communications between the networks on which the workstations of the employees of the Lazio Region and the Company are connected (connected to LAN networks accessible at the offices of the regional and Company offices) and those on which the server systems are connected; the second is used for filtering network traffic to and from the data center and communications between the networks on which the server systems are connected. In particular, the firewalling rules are configured based on the indications provided by the various project managers. In some cases, network traffic filtering is also implemented between the different architectural layers of a system (front-end, back-end, database) or for the different environments (development, testing, and production). Some critical systems or services [...] are instead connected to dedicated and physically separate networks compared to the other systems present in the data center”;

5. “At the end of July 2021, when the security incident subject to the inspection occurred, the filtering rules did not prevent, at the network level, the reachability of the server systems compromised from the network used for the VPN access of the employees of the Lazio Region, among which [...] the account of the employee]. For this reason, malicious actors were able to conduct reconnaissance of the server systems visible from the network used for VPN access, as well as to identify one with an outdated operating system (“RLWSIRIFT01”) affected by some known vulnerabilities. [...] one of these vulnerabilities was then exploited to acquire the authentication credentials with administrative privileges [...] used in the subsequent phases of the cyber attack”;

6. “Until June 30, 2021, it made use of a Security Information and Event Management (SIEM) service, based on IBM technology and provided by Fastweb S.p.a. under a Consip agreement. From XX, the Company activated a new SIEM service, based on Microsoft technology (Sentinel). At the time when the cyber attack occurred, the Company did not have personnel (internal or external) dedicated to the 24/7 analysis of alerts generated by the Microsoft SIEM, pending the activation of a security operations center (SOC) service provided by Leonardo S.p.a., which then occurred in the first days of August 2021”;

7. “At the time of the security incident, it used Dell’s Data Domain product as its backup management system. Specific backup management procedures had not been defined, but it was expected that each project manager would communicate, at the time of release into operation, using a specific model, among other things, information on the type and retention of backups to be performed. The frequency of backups was daily (starting at approximately 8:00 PM); it has conducted audit activities on the incident management process and has provided copies of the plans and audit reports;

8. “On an annual basis, it conducts internal audit activities on each of the processes provided for by the ISMS [...] The Company has planned, within the audit program for the year 2022, the execution of a specific audit activity on the security incident that occurred at the end of July 2021, also in order to close the observation made by the certification body (Apave Certification Italia S.r.l.) during the surveillance visit for the maintenance of ISO 27001 certification that took place on XX and XX.

1.2 Measures adopted following the violation

With reference to the measures adopted following the violation, the Company, with the supplementary notification of XX, represented that:

“at the time of the incident, along with taking the systems offline, corrective actions were implemented including: i) the establishment of a crisis team; ii) the enlistment of external consultants experienced in specialized activities of incident response, cyber security, and system remediation; iii) the reactivation of each application system subject to compatibility with the investigative activities and the verification of the security of the applications themselves, also resorting to bridge installations on Cloud environments provided by certified CSP providers Agid; iv) the activation of all activities and controls necessary to ensure the physical and logical security perimeter of the data center; v) the identification of a series of remedial actions to increase the security of the systems and the consequent protection of personal data, despite the pre-attack security levels already meeting industry standards, as the

Company had obtained ISO 27001 certification”;

“in all cases, a communication was made both on the institutional website of the Lazio Region and on that of Laziocrea to inform all users and interested parties of the actual extent of the service disruption and the risks related to personal data”;

“all applications both owned by Laziocrea and managed by Laziocrea as the Responsible Party of the Lazio Region or other Owners [...] have been restored. The processing managed on behalf of the Region as Responsible Party [...] (REG 09 – RES065 within the processing DSINF 45 -Development, Maintenance, Administration, User Assistance of the Management System for Notices and Calls of the Lazio Region for Culture) was restored from backup, and for the Cine Production and Cine Promotion Calls, while containing all the applications submitted, it encountered some issues with the restoration of the documentation attached to the aforementioned applications. The issue concerns the applications financed for the years 2017-2018-2019 and 2020, which are about 1,800; for some of these, it was not possible to restore all the attachments of the now archived applications from the backups [...]. There is, however, the possibility that some of the documents may not be restorable because the restored file is corrupted”;

“at present, there is no evidence of structured data exfiltration, although it cannot be absolutely ruled out that files containing information may have been viewed or consulted during the attack. During the time frame in which the ransomware propagation occurred, no connections to the outside were observed that would suggest a possible uncontrolled transfer of information.”

To carry out the data and system restoration operations, the Company represented that, in the absence of tools for decrypting the “files encrypted by the ransomware,” it recovered “portions of large files using data carving tools” (see par. 5 of the Executive & Technical Report of Leonardo S.p.a., annex B to the note of XX).

Furthermore, during the aforementioned inspection activities, it declared that:

“following the incident, a procedure with two-factor authentication was activated, based on the use of username/password and a one-time password (OTP)” (see minutes of XX, p. 3);

“following the violation of personal data, the password policies of accounts without administrative privileges were modified, increasing the minimum length to 10 characters” (see minutes of XX, p. 4);

“based on the indications provided by the Region in terms of priority in restoring services and in accordance with the investigative needs expressed by the judicial authority, the Company proceeded to reinstall all domain servers, including the domain controllers, using the intact copies of the various applications. In the context of this restoration activity, the Company also availed itself of the consultancy of Microsoft, which certified the absence of so-called ‘dummy accounts’ on the Active Directory that could have been created by malicious actors during the cyber attack” (see minutes of XX, p. 5);

“a new backup management system based on Commvault technology has been adopted, which is located on-premises at the Company’s data center, but which allows, where necessary, to also use the cloud service offered by the provider. The new system allows for easier management and monitoring of data and system backups. It is still expected that each project manager communicates, at the time of release into operation, through a specific model, among other things, information on the type and retention of backups to be performed” (see minutes of XX, p. 4);

“following the security incident, some services and systems have been restored, and are still provided, in a cloud environment, in particular: on Amazon’s AWS cloud (data center located in Lombardy) the healthcare service booking system (including vaccines and anti-SARS-CoV-2 swabs) and the regional vaccination registry; on Microsoft’s Azure cloud (data center located in Ireland) the Identity and Access Management system.”

management (IAM) and various institutional web portals (e.g., Lazio Region portal)”;

“following the security incident that occurred at the end of July 2021 [...] initiated a series of initiatives aimed at reviewing and strengthening the filtering rules applied to communications between and towards the server systems”;

“remote access to the systems and services present in the data center occurs via VPN (based on Pulse Secure technology). In this case, a first level of filtering policy is performed by the VPN concentrators that apply different privileges and rules based on the domain groups of which the user is

a member”;

“identified the (few) servers that, to ensure the operation of certain legacy services, still use obsolete operating systems and has taken appropriate measures for segregation, at the network level, as well as monitoring of security events”.

1.3 Information on the breach provided by the data controller

The Company provided a copy of the “notes sent to the Region [...], as well as the notes sent to the other Data Controllers,” specifying that the “notes sent to Controllers other than the Region have the same content, for which three models [...] of the three different notes sent are provided as examples” and attaching a “list of the Controllers [...] who received these notes, indicating the references of the Entity, the dates of transmission, and the protocol of LAZIOcrea” (see note of XX, p. 1).

With reference to the data controllers involved, among which is the aforementioned Company, the Company represented that it had sent them three communications:

with a note dated XX, it provided “information regarding the cyber attack on the Data Center of the regional Administration perpetrated by unknown cybercriminals on XX/XX,” “communicated so that the recipients have the elements to proceed independently with a preliminary notification of the data breach to the Guarantor for the protection of personal data”;

the Company highlighted that “the services and applications residing on the data center have been restored or will be restored in the coming days after verifying the removal of any residual and/or possible contamination and having reconfigured the systems with respect to the pre-existing security architecture. Starting from August 16, the third-party suppliers of applications residing in the data center will have the opportunity to reinstall their systems to resume the provision of related services” and communicated a series of corrective actions taken following the incident; this Company also represented that “checks were then carried out to assess whether the attack, which did not compromise the integrity and confidentiality of the data, allowed intruders to appropriate the same through exfiltration and/or transfer techniques,” which “confirmed that to date exfiltration can be ruled out as there were no data flows to the outside during the attack,” highlighting that “the technical details of the attack and each individual remedial action taken will be more fully presented in the final reports on the incident that are being drafted both by the independent team of experts and by the corporate structures responsible for security and data protection”;

with a note dated XX, it provided “further information regarding the cyber attack on the Data Center of the regional Administration perpetrated by unknown cybercriminals on XX/XX,” highlighting that “the investigations conducted have ascertained the sole compromise and loss of confidentiality [of ...] two corporate accounts excluding any compromise of the data managed by the applications and systems in operation in terms of integrity and confidentiality”;

with a note dated XX, it represented that “all application systems managed by LAZIOcrea have been restored both as data controller and as data processor on behalf of the Lazio Region and/or other subjects” and that “some informational websites are still being redesigned to improve their security given the obsolescence of the application platforms on which they were developed at the time”; the Company also highlighted that “the information received from the investigative Authorities (CNAIPIC, DIS, and CSIRT) leads to exclude that the data breach involved the exfiltration of data related to the processing carried out by LAZIOcrea both as Data Controller and as Processor,” also due to the fact that “no data has been published on the dark web even close to the deadline of the hackers’ ultimatum.”

During the investigation, it also emerged that several data controllers, after learning of the cyber attack through news reports, requested information from the Company regarding the matter.

1.4 Information provided by the Company

The Company, in response to the aforementioned requests for information, in the note dated XX, specifically represented that:

the Company, with a note dated XX, requested the Company for information regarding “which and how many personal data concerning the interested parties/patients/users of [...] the Company were, and in what way, involved in the data breach” (see note from the Company dated XX);

“following the cyber attack [...] the] Company has initiated all necessary activities to ensure a

minimization of the risks associated with the processing of personal data”;

“connectivity to the Regional Data Center has been isolated and an analysis of internal devices has been carried out to verify the possible

****Propagation of malware identified by Lazio Crea****;

*****“All analyses conducted have yielded negative results and, therefore, it appears that the company’s systems have not suffered any damage and the provision of related services has occurred continuously”*****;

*****“In light of the note sent by the Lazio Region on XX, which described the modalities of the cyber attack, internal procedures have been activated to allow users access to the services reserved for them and to the availability of the data of the interested parties”*****;

*****“Regarding the information provided to the interested parties, although, as already reported, the cyber attack did not directly affect the company’s systems and hospital services, communication measures have been activated to notify users of the incident both through the company’s official website and through social network platforms”*****;

*****“A corporate call center has been activated to allow bookings for specialist services, thus avoiding the use of the Lazio Crea systems.”***** Subsequently, in response to the further request for information aimed at obtaining a copy of the documentation regarding the personal data breach, held by the data controller pursuant to Article 33, paragraph 5, of the Regulation, the Company provided some elements (description of the breach; description of the systems, software, services, and IT infrastructures involved in the breach; technical and organizational measures in place at the time of the breach adopted to ensure the security of the personal data involved; technical and organizational measures adopted, or proposed for adoption, to remedy the breach and mitigate its possible negative effects for the interested parties; technical and organizational measures adopted, or proposed for adoption, to prevent similar future breaches; communications to the interested parties) highlighting that *****“any determination [...] is exclusively based on what was reported by the Lazio Region/LazioCrea S.p.A. through the official notes issued by them during the management and analysis of the aforementioned cyber attack”***** (see Company note of XX).

Based on the above, with note of XX (prot. XX) the Office made a notification of breach pursuant to Article 166, paragraph 5 of the Code to the Company, as it was found that the processing of personal data in question was carried out in violation of the obligations set forth in Article 33, paragraphs 1 and 5, of the Regulation by the Company in relation to the processing carried out as the data controller; With note of XX, the Company sent its defensive memoranda, in which it reiterated what had already been stated in the records, its cooperation with the Authority, and highlighted that it had also requested at the time of the contested facts an opinion from a law firm (opinion in records) in which it was highlighted that *****“according to the information in my possession, this event did not cause any malfunction or disruption for ASL Roma 3 and, above all, no attempts of unauthorized access to the IT systems or of theft, alteration, or destruction of personal data of the Company itself were recorded [...] In this context, it is the opinion that it is not necessary to notify the Guarantor for the protection of personal data unless, following further investigations or any communications from the Lazio Region and/or LazioCrea S.p.A., it should emerge that the data breach event also involved personal data, even if not necessarily of a sensitive nature, processed by Your Company. [...] In any case, but exclusively in the perspective of accountability, it is advisable to record the event that occurred on August 1st in the data breach register held by ASL Roma 3.”*****

****2. Outcome of the investigative activity.****

With reference to the applicable regulations, it is observed that: pursuant to the Regulation, “health-related data” are considered personal data concerning the physical or mental health of a natural person, including the provision of health care services, which reveal information related to their health status (Article 4, paragraph 1, no. 15, of the Regulation). Recital no. 35 of the Regulation further specifies that health-related data “include information about the natural person collected during their registration in order to receive health care services”; “a number, symbol, or specific element assigned to a natural person to identify them uniquely for health purposes”; the Regulation provides that personal data must be “processed in a manner that ensures adequate security [...] including protection against unauthorized or unlawful processing and against accidental

loss, destruction, or damage ('integrity and confidentiality')" (Article 5, paragraph 1, letter f), of the Regulation);

Article 33 of the Regulation establishes that "in the event of a personal data breach, the data controller shall notify the supervisory authority [...] without undue delay and, where feasible, within 72 hours of becoming aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons [...]" (paragraph 1) and that "where and to the extent that it is not possible to provide the information simultaneously, the information may be provided in phases without further undue delay" (paragraph 4);

the "Guidelines 9/2022 on the notification of personal data breaches under the GDPR" (hereinafter "Notification Guidelines"), adopted by the European Data Protection Board on March 28, 2023, highlight that "depending on the nature of the breach, the data controller may need to carry out further investigations to establish all relevant facts relating to the incident [...]. This means that the Regulation acknowledges that the data controller does not always have all the necessary information about a breach within 72 hours of becoming aware of it, as complete and comprehensive details about an incident are not always available within that timeframe. Therefore, the Regulation allows for phased notification. This is more likely to occur in the case of more complex breaches, such as certain types of cybersecurity incidents in which, for example, a thorough forensic investigation may be necessary to fully establish the nature of the breach and the extent of the compromise of personal data.

Consequently, in many cases, the data controller will need to conduct further investigations and follow up the notification by providing additional information at a later time. This is permitted provided that the data controller indicates the reasons for the delay, in accordance with Article 33, paragraph 1" (section II.B.2). This is also to allow the Supervisory Authority to assess the adequacy of the decisions made by the controller regarding communication to the data subjects and the measures taken to remedy the breach; the aforementioned Article 33 of the Regulation states that "the data controller shall document any personal data breach, including the circumstances surrounding it, its consequences, and the measures taken to remedy it" (paragraph 5); regarding the documentation of the breach, the Notification Guidelines establish that "regardless of whether a breach needs to be notified to the supervisory authority, the data controller must keep documentation of all breaches," which "this obligation is linked to the principle of accountability," as set out in Article 5, paragraph 2, of the Regulation and that "the purpose of keeping records of non-notifiable breaches, in addition to those that are notifiable, is also linked to the obligations of the data controller under Article 24, and the supervisory authority may request to consult such records. Consequently, the data controller is encouraged to create an internal register of breaches, regardless of whether they are required to notify or not" (section V.A); the same Notification Guidelines specify that "although it is up to the data controller to determine which method and structure to use to document a breach, certain key information should always be included," that the data controller is required to "record details related to the breach, including the causes, facts, and personal data involved. It should also indicate the effects and consequences of the breach and the measures taken to remedy it" and recommend "to also document the reasoning behind the decisions made in response to a breach. In particular, if a breach is not notified, it is appropriate to document a justification for that decision. The justification should include the reasons why the data controller believes it is unlikely that the breach poses a risk to the rights and freedoms of natural persons. Alternatively, if it believes that one of the conditions set out in Article 34, paragraph 3, is met, the data controller should be able to provide adequate evidence of the circumstance that applies in the specific case. If the data controller notifies a breach to the supervisory authority, but the notification is delayed, the data controller must be able to provide the reasons for the delay; documentation related to this circumstance could help demonstrate that the delay in reporting is justified and not excessive" (section V.A); the "Guidelines 01/2021 on examples concerning the notification of a personal data breach" (hereinafter "Guidelines on personal data breach cases"), adopted by the European Data Protection Board on December 14, 2021, referring to the Notification Guidelines, specify that the internal documentation of a breach is an obligation independent of the risks associated with the breach itself and must be prepared in each individual case (point 15); incidents caused by ransomware-type malware are a frequent cause of personal data breach notifications and can generally be classified as breaches of availability, but may also involve breaches

of confidentiality (point 16). In relation to examples of personal data breaches caused by ransomware (see cases 1, 2, 3, and 4), the same Guidelines emphasize the need for data controllers to document such types of breaches regardless of the associated risk to the rights and freedoms of the data subjects (see points 25, 35, 40, and 47). Acknowledging what has been represented by the Company in the documentation on file and in the defense briefs, it is observed that: with reference to the breach of the obligations under Article 33, paragraph 1, of the Regulation: in light of the unavailability, even prolonged, declared by the Company itself of certain systems managed by the Company (e.g., Telemed, Advice, systems designated for teleconsultation and tele-reporting in...

****Emergency) and health data processed by the Company as data controller****

The latter did not notify the personal data breach to the Authority, nor did it provide adequate documentation regarding the decisions made and the assessments carried out, capable of proving that, with reference to such processing, it was unlikely that the breach presented a risk to the rights and freedoms of the data subjects;

in this regard, the aforementioned Guidelines on notification remind us that “breaches can be classified based on the following three well-known principles of information security” and that a “breach of availability may occur in the event of loss, access, or accidental or unauthorized destruction of personal data.” In particular, the Guidelines highlight that “loss of availability may also occur in the event of a significant interruption of the usual service of an organization” and that “a ransomware infection (malicious software that encrypts the data of the data controller until a ransom is paid) could result in a temporary loss of availability if the data can be restored from a backup. However, there has still been an intrusion into the network, and notification may be required if the incident is classified as a breach of confidentiality (for example, if the attacker had access to personal data) and this presents a risk to the rights and freedoms of natural persons” (section I.B.2);

the Guidelines on cases of personal data breaches, in relation to some examples of personal data breaches caused by ransomware (see cases 2, 3, and 4), highlight that, in the event of a risk to the rights and freedoms of the data subjects, data controllers are required to notify the breach to the supervisory authority (see points 35, 40, and 47); for this purpose, it does not matter that the Company, after becoming aware of the incident, sent the Authority a copy of the note requesting information from the Lazio Region and the Company regarding the “data breach of August 1, 2021” (see the Company's note of XX);

with reference to the violation of the obligations under Article 33, paragraph 5, of the Regulation: from the documentation on file, it is also noted that the Company, contrary to what is indicated in the aforementioned legal opinion, did not adequately document the breach. In particular, only following specific requests for information from the Office, it prepared and provided the Authority with some documents that, taken together, are still lacking the key information indicated in the aforementioned Guidelines on notification, such as, for example, the effects and consequences of the breach for the data subjects, the reasoning behind the decisions made (including the decision not to notify the breach to the Authority), as well as the risk assessment arising from the breach.

****3. Conclusions.****

In light of the assessments mentioned above, taking into account the statements made by the Company during the investigation and considering that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code “Falsehood in declarations to the Authority and interruption of the execution of the tasks or the exercise of the powers of the Authority,” the elements provided in the defense memoranda do not allow for overcoming the observations notified by the Office with the initiation of the proceeding, nor do any of the cases provided for by Article 11 of the Authority's Regulation No. 1/2019 apply.

For these reasons, the preliminary assessments of the Office are confirmed, and the unlawfulness of the conduct adopted by the local health authority Roma 3 is noted, as detailed in the reasoning, in violation of Article 33, paragraphs 1 and 5, of the Regulation.

****4. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166,**

paragraph 7, of the Code).**

The violation of Article 33, paragraphs 1 and 5 of the Regulation, caused by the conduct of the Company, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraph 4 of the Regulation.

It should be noted that the Authority, pursuant to Articles 58, paragraph 2, letter i), and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Authority's Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 85, paragraph 2, of the Regulation, in relation to which it is noted that: the violation concerns the unavailability, even prolonged, of certain information systems used by the Company as data controller in which health data of the assisted individuals are processed.

(eg. Telemed, Advice) (art. 83, par. 2, lett. a) and g) of the Regulation);

the Company did not notify the personal data breach to the Authority, nor did it provide adequate documentation regarding the decisions made and the assessments carried out, capable of proving that, with reference to such processing, it was unlikely that the breach presented a risk to the rights and freedoms of the data subjects (art. 83, par. 2, lett. b) and h) of the Regulation);

the Company fully cooperated with the Authority during the investigation (art. 83, par. 2, lett. f) of the Regulation);

the facts occurred during the emergency context of Covid-19 (art. 83, par. 2, lett. k) of the Regulation);

the Company was informed late and only partially by the data controller regarding the breach in question, even following specific requests from the Company itself (art. 83, par. 2, lett. k) of the Regulation);

there are no previous relevant violations committed by the Company or previous measures referred to in art. 58 of the Regulation regarding the aforementioned provisions (art. 83, par. 2, lett. e) of the Regulation);

In light of these circumstances, it is believed that, in this specific case, the level of severity of the violations committed by the data controller is low (Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted by the Committee on May 23, 2023, point 60).

Based on the aforementioned elements, evaluated as a whole, it is deemed appropriate to determine the amount of the administrative fine provided for by art. 83, par. 3 and 4, of the Regulation in the amount of €10,000.00 (ten thousand) for the violation of art. 33, par. 1 and 5, of the Regulation, as an administrative pecuniary sanction deemed, pursuant to art. 83, par. 1, of the Regulation, effective, proportionate, and dissuasive.

Finally, it is noted that the conditions referred to in art. 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, are met.

ALL OF THE ABOVE, THE GUARANTOR

declares the illegality of the processing of personal data carried out by the local health authority Roma 3 for the violation of art. 33, par. 1, 2, and 5, of the Regulation as stated in the reasoning.

ORDERS

pursuant to arts. 58, par. 2, lett. i), and 83 of the Regulation, as well as art. 166 of the Code, the local health authority Roma 3, tax code 04733491007, represented by the legal representative pro tempore, to pay the sum of €10,000.00 (ten thousand) as an administrative pecuniary sanction for the violations indicated in this provision; it is noted that the offender, pursuant to art. 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction.

ORDERS

the aforementioned Company, in the event of failure to settle the dispute pursuant to art. 166, paragraph 8, of the Code, to pay the sum of €10,000.00 (ten thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with art. 27 of Law No. 689/1981.

DISPOSES

pursuant to art. 166, paragraph 7, of the Code, the full publication of this provision on the website of the Guarantor and the annotation of this provision in the internal register of the Authority, as provided for by art. 57, par. 1, lett. u), of the Regulation, of the violations and the measures adopted in accordance with art. 58, par. 2, of the Regulation.

Pursuant to art. 78 of the Regulation, arts. 152 of the Code, and 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, March 21, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei